

A Privacy Budgeting Framework for Online Experimentation

Gilian R. Ponte, Alina Ferecatu

Rotterdam School of Management, Erasmus University

Firms perform online experiments with multi-armed bandits to personalize what consumers are shown while balancing exploration and exploitation. However, third-parties can infer consumers’ underlying segments from observing which banners, ads, or recommendations consumers receive. To control this inference, we propose a privacy risk budget that firms can set *ex ante* to bound such third party belief updating using differential privacy. To spend this privacy risk budget, we propose two strategies: a constant privacy risk strategy and a dynamic privacy risk strategy that spend privacy risk differently across visitor. We study how privacy risk budgets affect experimentation performance in two applications—website design and a recommendation system—under these strategies. For both strategies, we analytically find privacy risk budgets that optimally balance exploration and exploitation. We then extend the idea of an experiment-level privacy risk budget to a firm-wide privacy risk budget. We apply this firm-wide privacy risk budget in an empirical setting with 78 experiments. We find that the dynamic strategy is particularly valuable in longer and more complex experiments, and that optimizing the allocation of a firm-wide privacy risk budget across experiments substantially improves learning performance.

Keywords: differential privacy; privacy risk budget; multi-armed bandits; online experimentation.

1. Introduction

Firms routinely experiment with website banners, links, and recommendations to improve engagement and profitability. However, online experimentation also raises privacy concerns, particularly because third-parties can track what consumers are shown and use those exposures to infer their interests and behaviors (Goldfarb and Tucker 2011, Summers et al. 2016, Kim et al. 2018, Shaddy et al. 2026). These concerns translate into economic costs for firms: consumers increasingly opt out of tracking (Tucker 2014, Johnson et al. 2020, Wang et al. 2024, Miller and Skiera 2024) and place a premium on privacy-respecting brands (Moffett et al. 2025).

To illustrate the privacy risk of experimentation, consider Jamie, a frequent reader of fantasy novels who visits the online bookstore Barnes & Noble. Third-party software that monitors the website, which we refer to as a tracker, may hold a prior belief that Jamie is a fantasy reader based on public information, such as their Goodreads account. Barnes & Noble first segments customers by book-genre preferences and then experiments to learn which output, such as a book recommendation, performs best for each segment.¹ To improve its recommendations, Barnes & Noble balances learning—randomly displaying different recommendations—with earning—using experimental results to select the currently best-performing recommendation.

This balance between learning and earning shapes Jamie’s privacy risk. Under optimization, the recommendation closely reflects Jamie’s segment and underlying preference, therefore introducing a privacy risk. By contrast, experimentation implies randomization, which makes recommendations stochastic and weakens the link to Jamie’s segment. Thus, optimization improves performance but increases privacy risk, whereas randomization strengthens privacy protection at the cost of displaying a suboptimal recommendation.

This privacy risk materializes when Jamie’s visit to Barnes & Noble allows the tracker to update its prior belief about Jamie’s book preferences through two information channels displayed in Figure 1: the experimental output, i.e., the book recommendation, and Jamie’s interaction with the output, i.e., a click on the recommended book (see Web Appendix A for a formal decomposition). The information available to the tracker depends on Jamie’s GDPR-style consent decision (Johnson et al. 2020, Choi et al. 2023), the use of an ad blocker (Todri 2022), and the privacy policies of the firm (Brough et al. 2022). When the information is not

¹ Barnes & Noble personalizes content and measures marketing effectiveness with third-party partners. Barnes&Noble (2026): “This is done so that we can personalize and enhance your browsing and shopping experience.”

The constant strategy has same privacy risk, therefore the same exploration probability throughout the experiment (middle and right panels), and it cannot adjust to this shift: it may explore too little early on, when learning is most valuable, and too much later on, when the best-performing arms have already become clearer. The expected regret reflects the inflexibility of the constant strategy. By replacing the exploration probability from Equation (12) into Equation (15), the regret bound of the constant strategy becomes (see Web Appendix H)

$$\mathbb{E}[R_{\text{constant}}(T)] \leq \underbrace{T \frac{K}{K + e^\gamma - 1}}_{\text{cost of exploration}} + \underbrace{\sqrt{K + e^\gamma - 1} \sqrt{T \log T}}_{\text{cost of exploitation}}. \quad (15)$$

Intuitively, the exploration term $T \frac{k}{k + e^\gamma - 1}$ grows linearly with the number of visitors because, in every round, the bandit explores with constant probability $\frac{k}{k + e^\gamma - 1}$ and a random pull can incur up to one unit of regret. The second term, $\sqrt{k + e^\gamma - 1} \sqrt{T \log T}$, captures exploitation mistakes due to noisy value estimates. A smaller privacy budget γ decreases the exploitation probability, which decreases the cost from uncertainty during learning, but also increases the exploration probability, which raises the exploration cost. This is the core exploration–exploitation trade-off in online experimentation under privacy protection. To incorporate this idea, we next vary privacy risk across visitors so that exploration is concentrated earlier in the experiment and exploitation later.

3.3.2. Dynamic privacy risk strategy. We next derive a dynamic privacy risk schedule that varies risk across visitors to better balance exploration and exploitation than the constant strategy and gets closer to the expected regret bound of the ε -greedy policy without privacy protection (see Equation 6). Under this dynamic strategy, the privacy risk assigned to visitor t is given by (see Web Appendix D.2):

$$\xi_t = \log \left(1 - K + \frac{K}{\left(\frac{K \log(t)}{t} \right)^{1/3}} \right). \quad (16)$$

Under this schedule, the firm can protect visitors' privacy without degrading learning performance relative to an ε -greedy policy without privacy protection. However, to ensure that privacy risk never exceeds the predetermined budget γ in Equation (14), we cap the per-visitor privacy risk as follows:

$$\xi_t = \min \left\{ \gamma, \log \left(1 - K + \left(\frac{K}{\left(\frac{K \log(t)}{t} \right)^{1/3}} \right) \right) \right\}. \quad (17)$$

This cap implies that once the budget binds, the exploration and exploitation probabilities are fixed, and the privacy risk ξ_t remains set at γ , ensuring that the experiment-wide privacy guarantee is preserved. The cap effectively binds the extent of exploitation the bandit can engage in, and ensures that even after many visitors the bandit still explores and randomizes assignment, thus allowing plausible deniability.

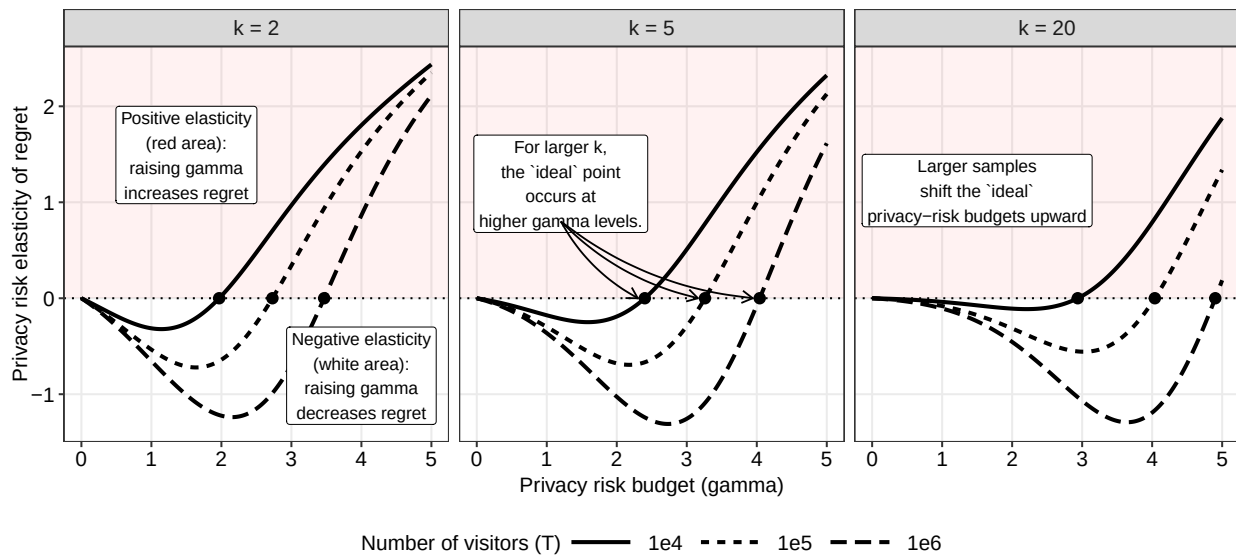
In Figure 5, we visualize the privacy risk (left panel), the probability of exploitation (middle panel), and the probability of exploration (right panel) under the dynamic privacy risk strategy. Early visitors face lower privacy risk as the bandit explore more, while later visitors face higher privacy risk, as the bandit exploits more frequently. When $\xi_t > \gamma$, the privacy risk and induced exploration and exploitation probabilities are constant.

The introduction of the budget cap in Equation (17) creates an additional regret component relative to the standard ε -greedy bound: once the cap takes effect, the strategy is forced to randomize more than the uncapped schedule would prescribe late in the experiment, which increases regret. This strategy yields the following expected regret bound (see

5.1. The privacy elasticity of regret for the constant strategy

We derive the privacy elasticity of regret for the constant strategy in Web Appendix I.1. Figure 8 plots this elasticity as a function of the privacy budget γ . The x -axis shows the privacy budget γ and the y -axis shows the percentage change in expected regret resulting from a one-percent increase in γ . The panels vary the number of arms $K \in \{2, 5, 20\}$ and the line types represent different numbers of visitors T .

Figure 8 Privacy risk elasticity of regret as a function of the privacy budget γ , for different numbers of arms ($K \in \{2, 5, 20\}$) and visitors ($T \in \{10, 100, 1,000, 10,000\}$).



Note. The elasticity is negative where relaxing privacy protection (increasing γ) reduces regret, and positive where further increases in γ raise regret. The zero-crossings mark is the ideal privacy budgets that minimize regret for each (k, T) combination.

The sign of the elasticity provides a managerial diagnostic of where the constant strategy is “too random” versus “too greedy.” When the elasticity is negative, increasing γ (i.e., allowing less randomization) reduces regret because the bandit can exploit more effectively. When the elasticity becomes positive, further increases in γ increase regret because the constant strategy explores too little and can lock in to a suboptimal arm (see the left panel in Figure

strategy regime. The flexible regime allows the firm to choose, for each experiment, whether to use the constant or dynamic privacy budgeting strategy. By contrast, the constant regime restricts all experiments to use the constant strategy, and the dynamic regime restricts all experiments to use the dynamic strategy. The dashed horizontal line at zero indicates the random (lower bound) benchmark, equivalently the $\Gamma = 0$ case. The solid horizontal line indicates the upper bound γ^* benchmark. We use text annotations to highlight the difference in median clicks between the managerial heuristic and the regret-based allocation benchmark.

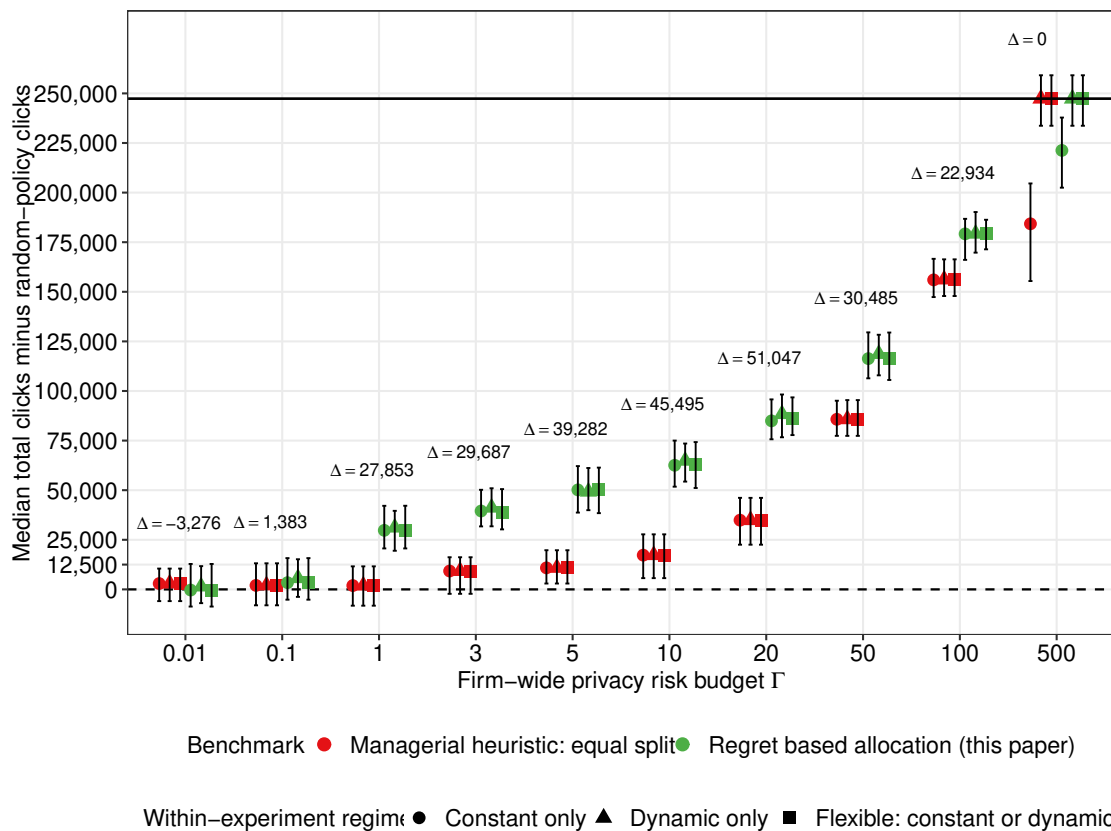


Figure 12 Median improvement in portfolio clicks relative to the random-policy baseline across firm-wide privacy budgets. Points report medians over simulation repetitions, and error bars show the interquartile range. Colors indicate the firm-wide allocation rule, while shapes indicate the within-experiment budgeting regime.

This privacy risk is controlled by the privacy-preserving assignment mechanism in Equation (13). Conditional on GA’s historical information, the measurement environment, and the GA channel being active, we bound the posterior-odds multiplier from observing the displayed arm:

$$R_A(a) \leq e^\gamma.$$

A.2. Privacy risk from behavior after experimental output

Second, if GA also observes behavior directly related to the experimental output, this behavior may create an additional source of posterior updating. For example, after observing that customer i was shown arm $A_i = a$, GA may also observe whether the customer clicked on that experimental arm. Conditional on the displayed arm, the experiment-specific behavioral-response factor is

$$R_{Y^E}(y^E) = \frac{\Pr(Y_i^E = y^E \mid H_i^{GA}, \Omega, G_i = 1, A_i = a, S_i = s)}{\Pr(Y_i^E = y^E \mid H_i^{GA}, \Omega, G_i = 1, A_i = a, S_i = s')}.$$

This factor measures how informative the customer’s experiment-specific response is once exposure has already occurred. For instance, if customers in segment s are more likely than customers in segment s' to click on arm a , then observing a click on the experimental output increases GA’s belief that the customer belongs to segment s .

A.3. The full posterior update

The model of privacy risk in experimentation is conditional on the GA observation channel being active. If $G_i = 0$, GA receives no current experimental signal, so the current experiment generates no output- or response-based posterior update. Conditional on $G_i = 1$, the posterior update depends on which experimental signals are observed under the measurement architecture Ω . If GA observes the displayed arm but not the experiment-specific response, then

$$\frac{\Pr(S_i = s \mid H_i^{GA}, \Omega, G_i = 1, A_i = a)}{\Pr(S_i = s' \mid H_i^{GA}, \Omega, G_i = 1, A_i = a)} = \frac{\Pr(S_i = s \mid H_i^{GA}, \Omega, G_i = 1)}{\Pr(S_i = s' \mid H_i^{GA}, \Omega, G_i = 1)} R_A(a).$$

If GA observes both the displayed arm and the raw experiment-specific response, then

$$\begin{aligned} & \underbrace{\frac{\Pr(S_i = s \mid H_i^{GA}, \Omega, G_i = 1, A_i = a, Y_i^E = y^E)}{\Pr(S_i = s' \mid H_i^{GA}, \Omega, G_i = 1, A_i = a, Y_i^E = y^E)}}_{\text{posterior odds}} \\ &= \underbrace{\frac{\Pr(S_i = s \mid H_i^{GA}, \Omega, G_i = 1)}{\Pr(S_i = s' \mid H_i^{GA}, \Omega, G_i = 1)}}_{\text{prior odds conditional on access}} \underbrace{R_A(a)}_{\text{experimental-output privacy risk}} \underbrace{R_{Y^E}(y^E)}_{\text{experiment-specific behavior privacy risk}}. \end{aligned}$$

Web Appendix B: Differential privacy in the context of bandits

A randomized mechanism $\mathcal{M}$ satisfies ξ -differential privacy if, for any two neighboring datasets D and D' that differ in at most one individual, and for all measurable events S in the output space,

$$\mathbb{P}(\mathcal{M}(D) \in S) \leq e^\xi \mathbb{P}(\mathcal{M}(D') \in S). \quad (22)$$

In our setting, let $D = (a_1, \dots, a_T)$, where $a_t \in \{0, 1\}$ denotes the non-private arm label associated with visitor t . A neighboring dataset is $D' = (a_1, \dots, a'_t, \dots, a_T)$, which differs from D only in the t -th entry, with $a_t \neq a'_t$.

At round t , the ε -greedy rule in Equation (4) induces a random mapping from the non-private arm label a_t to the displayed arm a_t^* . Applying this mapping independently across visitors yields the overall mechanism

$$\mathcal{M}(D) = (a_1^*, \dots, a_T^*).$$

Under this conditional independence assumption, the joint output distribution factorizes across visitors, so the privacy condition in Equation (22) becomes

$$\mathbb{P}(\mathcal{M}(a_1, \dots, a_T) = (a_1^*, \dots, a_T^*)) \leq e^\xi \mathbb{P}(\mathcal{M}(a_1, \dots, a'_t, \dots, a_T) = (a_1^*, \dots, a_T^*)). \quad (23)$$

Because D and D' differ only in the t -th entry, all terms except the t -th cancel in the likelihood ratio. Hence, the privacy requirement reduces to the one-visitor condition

$$\mathbb{P}(a_t^* = j \mid a_t = 0) \leq e^\xi \mathbb{P}(a_t^* = j \mid a_t = 1), \quad \forall j \in \{0, 1\}. \quad (24)$$

Equation (24) implies that observing a particular displayed output does not allow an outside observer to sharply distinguish between the two possible underlying visitor types. Even if Jamie's underlying arm label were different, the probability of observing the same displayed output could change by at most a factor of e^ξ .

Web Appendix C: Parallel composition

For T visitors, let $A = (a_1, \dots, a_T)$ denote the vector of (possibly adaptive) arm choices, where $a_t \in \{1, \dots, k\}$ is the arm selected by the bandit at round t . The displayed arm is generated by a per-visitor randomizer $\mathcal{M}_t: a_t \mapsto a_t^*$, implemented via the stochastic matrix P_t (see Equation (10)). We assume the privacy schedule $(\xi_t)_{t=1}^T$ (equivalently, $(P_t)_{t=1}^T$) is fixed ex ante. Let $q_t(\cdot \mid a)$ denote the conditional probability mass function of $\mathcal{M}_t(a)$, i.e., $q_t(a_t^* \mid a_t) = (P_t)_{a_t^*, a_t}$.

We make the following assumptions: